

GUARDAI

Technical Architecture & Specification: Autonomous AI-Powered SOC Analyst SaaS

Project Name: GuardAI

1. EXECUTIVE OVERVIEW

GuardAI is an enterprise-grade, AI-powered SOC Analyst SaaS platform engineered to automate security log processing, threat detection, and incident response. By integrating Retrieval-Augmented Generation (RAG) with real-time stream analysis, GuardAI reduces Mean Time to Detect (MTTD) and Mean Time to Respond (MTTR) for enterprise security teams. The platform operates on an isolated 3-Tier Multi-Tenant RBAC Architecture.

2. GLOBAL SECURITY & INPUT VALIDATION ARCHITECTURE

Every form, input field, background worker, and API endpoint across the entire application must adhere to this global security baseline:

Input Validation & Sanitization

- **Schema Validation:** Strict client-side and server-side schema validation using Zod.
- **Regex Pattern Matching:** Advanced RegEx pattern matching for all input fields (Email structure, complex password rules, and log file integrity checks).
- **XSS Prevention:** Cross-Site Scripting (XSS) prevention via HTML sanitization and React auto-escaping mechanisms.

API & Route Protection

- **Middleware Guarding:** Next.js Middleware for session verification and role-based route guarding.
- **CSRF Protection:** Cross-Site Request Forgery (CSRF) protection using secure HTTP-only SameSite cookies.
- **Rate Limiting:** Multi-layer Rate Limiting per IP address and per Workspace via Upstash Redis.

Database Isolation

- **Row Level Security:** Mandatory PostgreSQL Row Level Security (RLS) policies applied to every database query.

3. RBAC ROLES & PERMISSIONS MATRIX

A. Super Admin (Platform Owner Level)

- **Subscription Exemption:** Free or Pro subscription tier constraints do not apply to Super Admin accounts (Unlimited System Access).
- **Global Analytics:** Access to platform-wide metrics (Total Tenants, Active Users, System API Usage, AI Token Consumption, Total Scanned Logs).
- **Tenant Management:** Complete oversight of all Workspaces, audit capabilities, and one-click Suspend / Ban functionality for abusive tenants.
- **User Management:** Global user administration (force logout, account suspension, and complete account deletion).
- **Global Audit Logs:** Comprehensive tracking of all administrative actions (e.g., manual user bans, configuration overrides).

B. Tenant Admin / Workspace Owner (Client Level)

- **Self-Signup Provisioning:** Automatically assigned role upon completing standard self-registration.
- **Billing & Subscriptions:** Full subscription lifecycle management (Free Tier vs. Pro Plan), Lemon Squeezy Checkout handling, and team seat allocations.
- **Team Onboarding:** Ability to invite Workspace Members/SOC Analysts via email and manage or revoke member roles.
- **Workspace Settings:** Workspace renaming, custom SOC rule configurations, and API key management.
- **Logs & Threat Intelligence:** Ingesting workspace security logs, reviewing threat analysis, and executing remediation playbooks.

C. Member / SOC Analyst (Team Level)

- **Restricted Access:** Strictly No Access to Billing, Subscription details, Workspace Settings, or Team Invitation screens.
- **Core Capabilities:** Security log uploading, AI Threat Dashboard access, and viewing/executing AI-generated Threat Reports and Remediation Plans.
- **Profile Management:** Managing personal profile settings, updating passwords, and configuring Multi-Factor Authentication (MFA).

4. IMPLEMENTATION ROADMAP

Phase 1 – Authentication, RBAC, Multi-Tenancy & Security Baseline

1. Authentication Screens & Specifications

Sign-Up Page:

- **Fields:** Full Name, Work Email, Password, Confirm Password, Workspace Name.
- **Validations:** Strict email format RegEx, Password strength rules (min 8 characters, 1 uppercase, 1 lowercase, 1 number, 1 special character), password match verification.
- **Methods:** Email/Password registration with email confirmation + Google OAuth (auto-provisions Workspace).
- **Role Assignment:** Signing-up user is automatically granted the Tenant Admin role for their created workspace.

Login Page:

- **Fields:** Email, Password, "Remember Me" checkbox.
- **Security:** Brute-force protection (Account locked for 15 minutes after 5 consecutive failed attempts via Upstash Redis).
- **Redirection Logic:** Role-based routing upon login (Super Admin /super-admin, Tenant Admin/Member / dashboard).

Logout Functionality:

- **Triggers & UI Placements:** User Avatar Dropdown (Top Navigation Bar) on all Dashboard screens, Sidebar Footer Navigation Link, and Global Profile Settings page.
- **Session Termination Logic:** Invokes Supabase Auth `signOut()` API to terminate JWT access and refresh token session instantly on server and client side.
- **Cookie & Local Storage Invalidation:** Explicitly clears server-side HTTP-only session cookies (sb-access-token, sb-refresh-token), flushes local browser storage session states, and resets client React state.
- **Global Route Invalidation:** Instantly invalidates Next.js route cache and prevents backward browser navigation to cached /dashboard or /super-admin screens via Middleware Guarding.

- **Post-Logout Redirection:** Automatically redirects user to the /login page with a notification confirming successful logout.

Forgot / Reset Password Flow (6-Digit OTP + Redis Protection):

- **Page 1 (Forgot Password Request):** Work Email input field with pattern validation. Triggers a 6-digit numeric OTP code sent via Supabase Auth to the user's email.
- **OTP Rate-Limiting & Spam Prevention:** Upstash Redis tracks OTP requests per email/IP (Enforces a max limit of 3 resend attempts per 15 minutes to prevent brute-forcing and email spamming).
- **Page 2 (OTP Verification):** Six individual auto-focusing numeric input fields with backspace navigation, auto-submit on completion, and a 60-second cooldown timer for the "Resend OTP" button.
- **Page 3 (Password Reset):** New Password & Confirm New Password input fields with real-time password strength meter and strict RegEx checks.

2. Multi-Tenancy, Database Synchronization & RBAC Engine

- **Supabase Auth Setup:** User session management with JWT tokens containing embedded custom claims (workspace_id and role).
- **Instant Profile Synchronization (Database Trigger):** Implements an automated PostgreSQL Database Trigger (on_auth_user_created) linked to Supabase Auth. Automatically creates and synchronizes user entries in the profiles table immediately upon registration or member invitation signup, completely eliminating state mismatches, UI delays, or race conditions.
- **Database Schema Architecture:**
 - profiles: (id, email, full_name, global_role [super_admin, user])
 - workspaces: (id, name, owner_id, plan [free, pro], subscription_status)
 - workspace_members: (workspace_id, user_id, workspace_role [tenant_admin, member])
- **Strict RLS Isolation:** Database RLS policies automatically filter queries using custom JWT claims. Workspace A can never query or access Workspace B's data under any condition. Super Admin accounts bypass workspace filters via explicit admin policies.

Phase 2 – GuardAI Foundation, Ingestion & RAG Pipeline

1. Asynchronous Security Log Ingestion Pipeline

- **Drag & Drop Upload Component:**
 - **Supported Formats:** Strictly .json, .csv, .syslog, and log formats.
 - **Validation Controls:** File size limits (Free: Max 10MB, Pro: Max 100MB), MIME-type verification, and malicious payload sanitization.
 - **UI Feedback:** Interactive upload progress bar, log parsing status, and structured validation error alerts for malformed logs.
- **Asynchronous Background Processing (Non-Blocking CPU Thread):** Log sanitization (PII masking) and parsing offloaded to a background queue (Upstash QStash / BullMQ) to prevent blocking the main Node.js event loop during heavy uploads.

2. Processing & High-Performance Vector Store

- **Chunking & Vector Generation:** Chunks processed logs using overlapping strategies and generates high-dimensional embeddings via LLM APIs.
- **Optimized pgvector Store:** Vectors stored directly inside PostgreSQL using pgvector, secured with workspace_id RLS.

- **Composite Index Optimization:** Utilizes composite indexes (ivfflat/hnsw) coupled with workspace_id filtering to maintain sub-second query performance during cosine similarity vector searches on large multi-tenant datasets.

3. RAG Engine & Threat Intelligence

- Executes vector similarity searches using cosine similarity matching within pgvector.
- Feeds context-matched vectors and queries to LLMs using Vercel AI SDK.
- Generates structured JSON outputs: Threat Type, Severity Score (1-10), Contextual Explanation, and Remediation Steps.

Phase 3 – Real-Time AI SOC Dashboard & Generative UI

1. SOC Intelligence Center (Dashboard)

- **Analytics Widgets:** Total Threats Detected, Critical Risk Gauge, Interactive Attack Vector Visuals, Real-Time Stream Log Output.
- **Role-Based UI Rendering:**
 - **Tenant Admin View:** Displays Upgrade Button, Team Invite Modal, Log Stream, and Reports.
 - **Member View:** Displays Log Stream and Reports (Billing, Upgrade, and Workspace Settings are completely hidden).
 - **Super Admin View:** Displays Platform Management Banner and Admin Portal Navigation Link.

2. Streaming & Generative UI

- Real-time text response streaming via Vercel AI SDK without blocking UI interactions.
- **Dynamic UI Components:** Streaming responses dynamically render interactive UI elements like Actionable Remediation Cards, Threat Severity Badges, and Warning Alerts.

3. UX Polish & Micro-Interactions

- Fluid page transitions, tab switches, and hover states powered by Framer Motion.
- Skeleton loading states to eliminate layout shifts or blank screens.
- Interactive Remediation Checklists allowing SOC analysts to mark threat mitigation steps as "Pending", "In Progress", or "Resolved".

Phase 4 – Monetization, Metering, Team Invites & Production Launch

1. Subscription Tiers & Secure Webhooks (Lemon Squeezy Integration)

Feature / Parameter	Free Tier	Pro Tier
Seat Allocation	1 Workspace Admin + 1 Member seat	Up to 10 Member seats
Log Scan Quota	5 Scans / day	Unlimited daily scans
Max File Upload	10 MB	100 MB
AI Priority	Standard Execution	Priority AI Execution

- **Lemon Squeezy Integration:** Hosted checkout overlay, webhook processing for subscription_created, subscription_updated, and subscription_cancelled events.
- **Mandatory Webhook Security:** All incoming Lemon Squeezy webhooks verify HMAC-SHA256 signatures using the secret key before processing payloads to prevent unauthorized subscription injection.

2. Workspace Team Invitation Flow

- 1. Tenant Admin inputs Member Email:** System generates a secure, tokenized invitation link.
- 2. Recipient clicks link:** Directed to dedicated Member Registration Page → Account created and automatically linked to the inviter's workspace_id with the Member role.

3. Atomic Rate Limiting & Metering (Upstash Redis)

- **Atomic Sliding Window Metering:** Uses Redis atomic commands (INCR / DECR within EVAL Lua scripts) to handle daily scan quotas (5 Scans/day for Free Tier). Naive GET/SET operations are strictly avoided to eliminate race conditions during concurrent API uploads.
- **Limit Enforcement:** When a Free user exceeds their quota, an "Upgrade to Pro" modal pops up with direct Lemon Squeezy payment buttons.

4. Super Admin Portal (/super-admin)

- **Dedicated Admin Interface:** Strictly accessible if `global_role === 'super_admin'`.
- **Tenant Management Table:** Interactive list of all Workspaces, active plans, total logs scanned, creation date, and status (Active/Suspended).
- **Tenant Controls:** One-click "Suspend Workspace" or "Reactivate Workspace" toggles.
- **System Health Metrics:** Real-time graphs for Global API Usage, Token Consumption, and Total Active Subscriptions.